

UST-2026-09-27-20

Cloudflare · Security Insights: los 13 hallazgos del 21/24-sep, uno a uno — qué es cada uno, qué riesgo real tiene en nuestro sitio, qué se hace (paso a paso en el panel) y cómo se comprueba

PROPUESTA (27-sep 01:3x, madrugada tras la entrega A de UST-19). Lo que se afirma del estado actual está MEDIDO desde fuera (dns.google el 27-sep 01:2x: SPF y DKIM presentes, `\_dmarc` AUSENTE) o leído del propio listado de Insights; lo que no se ha podido medir desde el sandbox (cabecera HSTS, plan de la zona) lleva su comprobación en el PASO 0. Carril técnico salvo D4 (qué hacemos con los rastreadores de IA: marketing → Pilar y Lucía).

1 · El pedido, literal

Juanjo, 27-sep-2026 ≈01:15, tras desplegar la entrega A de UST-19:

«en cloudflare, en la parte de seguridad tenemos que mejorar la configuracion, me puedes dar para cada uno de los findings aquí abajo, una ust con las acciones a realizar y cambios en cloudflare, una a una y el paso a paso para corregirlos»

Listado pegado (Security Insights, activos, 13): Security.txt not configured (nutrisynccollective.com, Low) · Standard Super Bot Fight Mode not enabled/optimized (Moderate) · DMARC Record Error detected (Low) · Domains without HSTS (admin.nutrisynccollective.com, Moderate) · Domains without HSTS (nutrisynccollective.com, Moderate) · Managed Rules not deployed (Critical) · Review unwanted AI crawlers with AI Labyrinth (Low) · Domains without HSTS (app.laramagonzalez.com, Moderate) · Review unwanted AI crawlers with AI Labyrinth (laramagonzalez.com, Low) · Bot Fight Mode not enabled (laramagonzalez.com, Moderate) · Security.txt not configured (laramagonzalez.com, Low) · Users without MFA (juanjose.cebrian@outlook.com, Moderate) · No Turnstile enabled (This account, Low).

Lectura: no «poner todo en verde» a ciegas, sino decidir hallazgo a hallazgo qué riesgo real tiene para NutriSync, qué se activa (con el paso a paso exacto del panel y su marcha atrás), qué se deja a propósito con motivo escrito (como Bot Fight Mode, D6 de UST-19), y qué no es nuestro (laramagonzalez.com). Cada acción lleva su comprobación desde fuera (curl / dns.google / re-escaneo de Insights) para que «hecho» signifique medido.

Principio (stack lean, Juanjo 2-ago)

Sin proveedores ni planes nuevos por defecto: todo lo que se propone activar está en el plan Free de Cloudflare. Lo único que costaría dinero (Pro, para el WAF gestionado completo y Super Bot Fight Mode) se plantea como decisión con cifra, no se da por hecho.

Reparto (regla 2-sep)

Todo es carril técnico (Juanjo decide y ejecuta en el panel; Pilar y Lucía lo corroboran en el hub) salvo qué hacer con los rastreadores de IA sobre la web pública: eso es marketing (visibilidad de la marca en asistentes de IA) → ☐ CF-1, firma de las dos.

2 · Lo que hay hoy (medido desde fuera el 27-sep 01:2x, o leído del panel)

Qué	Medido
Correo (SPF · DKIM · DMARC)	SPF publicado: `v=spf1 include: spf-eu.ionos.com ~all` ✓. DKIM: `s1-ionos._domainkey` → `s1.dkim.ionos.com` ✓ (los CNAME de IONOS del 2-sep). **DMARC: el TXT `_dmarc.nutrisynccollective.com` NO EXISTE** (dns.google devuelve NODATA; tampoco existe con el sufijo duplicado `_dmarc.nutrisynccollective.com.nutrisynccollective.com`, el error típico al pegar el nombre completo). La memoria del 2-sep decía «+ TXT _dmarc (p=none; rua=)»: o no se llegó a crear o se borró — el hallazgo «DMARC Record Error» es exactamente eso, y es el único de los 13 que toca algo que ya nos costó (la mitad de la wave-2 en spam).
HSTS	Sin medir desde el sandbox (sin red directa). Se mide en el paso 0 con `curl -sI https://nutrisynccollective.com   grep -i strict` (y admin., m., v2.). Todo el tráfico ya es HTTPS (Pages) y «Always Use HTTPS» redirige; lo que falta es la CABECERA que le dice al navegador que no vuelva a probar HTTP.

Qué	Medido
security.txt	No existe. Pages sirve <code>`/.well-known/security.txt`</code> con 200 y la portada (lección r13: una URL inexistente no da 404), por eso el escáner lo marca como «not configured». Hoy nadie externo sabe a qué buzón reportar una vulnerabilidad.
Bots	Bot Fight Mode APAGADO a propósito (UST-19 D6: en Free no admite excepciones y desafiaría a smoke-prod, curl y Lighthouse). Super Bot Fight Mode es de plan Pro. Lo que sí hay: Turnstile en el único formulario público que escribe (UST-19 A), regla WAF de rate limiting 10 req/10 s en <code>`/api/waitlist`</code> , validación en la Edge y el REST anónimo cerrado.
WAF gestionado	El panel dice «Managed Rules not deployed». En Free, Cloudflare despliega por defecto un conjunto reducido («Free Managed Ruleset», unas pocas reglas para CVE de alto impacto); el conjunto completo (Cloudflare Managed Ruleset + OWASP Core) es de Pro. Qué muestra exactamente nuestro panel se lee en el paso 0 (Security → WAF → Managed rules).
Rastreadores de IA	Cloudflare antepone su bloque gestionado a nuestro <code>`robots.txt`</code> (<code>`Disallow: /`</code> para GPTBot, ClaudeBot, etc.; lección r26-k: el smoke lo lee por grupo). Es solo una petición educada: un rastreador que la ignora entra igual. AI Labyrinth (Free, beta) sirve enlaces trampa a los que no la respetan. Nadie ha decidido si QUEREMOS que los asistentes de IA conozcan la web.
Cuenta Cloudflare	<code>`juanjose.cebrian@outlook.com`</code> sin segundo factor (hallazgo «Users without MFA»). Es la cuenta que aloja las tres Pages, el DNS, Access (Zero Trust) y Turnstile: una contraseña filtrada = la web, el hub y el correo (DNS) en manos ajenas. Es también la cuenta de GitHub (mapa canónico). Miembros: solo Juanjo (a confirmar en Manage Account → Members).
Turnstile (cuenta)	Hallazgo del 24-sep, ya RESUELTO el 26-sep con el widget «NutriSync web» (UST-19 A). Desaparece en el siguiente escaneo; nada que hacer.
laramagonzalez.com (4 hallazgos + HSTS de app.)	Dominio familiar en la misma cuenta (r26-c: por eso el team de Zero Trust se llama `larama-familia-2026`). No es NutriSync: se dan las mismas recetas para que Juanjo las aplique si quiere (allí Bot Fight Mode SÍ puede activarse: no hay smoke ni automatismos que romper), pero no entran al tablero.

Analogía: Security Insights es como el informe de la ITV del coche: mezcla lo grave con lo cosmético y no sabe cómo usas tú el coche. HSTS y DMARC son los frenos y el cinturón (baratos, se hacen ya); el WAF gestionado completo es un airbag lateral de pago para un coche que casi no sale a la autopista (sitio estático sin origen propio); Bot Fight Mode es una alarma que salta con el propio mecánico (smoke, curl) y ya decidimos no ponerla; security.txt es el papel con el teléfono del taller en la guantera; el MFA de la cuenta es la llave del garaje donde está todo lo demás.

3 · Hallazgo a hallazgo: qué es, qué se hace (paso a paso en el panel) y cómo se comprueba

Qué	Qué se hará (paso a paso)	Cómo se verificará
F0 · PASO 0 · Baseline antes de tocar nada	Terminal (Juanjo): <code>`for h in nutrisynccollective.com admin.nutrisynccollective.com m.nutrisynccollective.com v2.nutrisynccollective.com; do echo "\$h: \$(curl -sI https://\$h   grep -i strict-transport-security    echo sin-HSTS)"; done`</code> · <code>`curl -sI https://nutrisynccollective.com/.well-known/security.txt   head -3`</code> · <code>`dig TXT _dmarc.nutrisynccollective.com +short`</code> (esperado vacío) · captura del listado Security → Insights (los 13) · en el panel: Security → WAF → Managed rules (qué conjuntos hay y su estado) · DNS → Records: lista de TODOS los hosts (para D1) · Manage Account → Members (para D7). Todo pegado en el chat: es la foto que se compara al final.	La foto existe antes del primer clic (regla UST 7-sep: baseline escrita o no hay marcha atrás).
F1 · Security.txt not configured (nutrisynccollective.com · Low)	Panel: zona nutrisynccollective.com → Security → Settings → «Security.txt» (Cloudflare lo sirve en <code>`/.well-known/security.txt`</code> antes de llegar a Pages) → Enable → Contact: <code>`mailto:engineering@nutrisynccollective.com`</code> y <code>`mailto:contact@nutrisynccollective.com`</code> (los dos buzones existen en IONOS) · Expires: 27-sep-2027 · Preferred-Languages: <code>`en, es`</code> · Canonical: <code>`https://nutrisynccollective.com/.well-known/security.txt`</code> · Policy: <code>`https://nutrisynccollective.com/legal/privacy.html`</code> (hasta que exista una página de divulgación responsable) · Encryption/Acknowledgments/Hiring: vacíos → Save. Alternativa (D5): fichero en <code>`repos/webdeploy/_integration/.well-known/security.txt`</code> copiado por <code>integrate.py</code> — vive en el repo y lo prueba web-tests, pero exige un po.	<code>`curl -s https://nutrisynccollective.com/.well-known/security.txt`</code> devuelve texto plano con <code>`Contact:`</code> y <code>`Expires:`</code> (no la portada). Smoke: check nuevo «security.txt sirve y no caduca en < 30 días». Insight desaparece en el siguiente escaneo.

Qué	Qué se hará (paso a paso)	Cómo se verificará
F2 · Standard Super Bot Fight Mode not enabled/optimized (nutrisynccollective.com · Moderate)	NO SE ACTIVA (decisión D6 de UST-19, firmada el 26-sep): Super Bot Fight Mode es de plan Pro, y el Bot Fight Mode de Free no admite excepciones y desafiaría a smoke-prod, a los curl de verificación y a Lighthouse. El hallazgo se ARCHIVA en el panel con motivo (Security → Insights → seleccionar → Archive) y queda escrito aquí: el riesgo de bots sobre lo único que escribe desde fuera (la lista de espera) ya está cubierto por Turnstile + rate limiting + Edge + REST cerrado (UST-19 A). Se revisa si algún día hay Pro (Super BFM permite reglas de exclusión) — D3.	Insight en «Archived» con la nota. La web sigue respondiendo a curl/smoke sin desafíos (smoke PRODUCCIÓN SANA).
F3 · DMARC Record Error detected (nutrisynccollective.com · Low — pero REAL)	Medido: el TXT `_dmarc` no existe. Opción recomendada (D6): zona → Email → «DMARC Management» → Enable → el asistente propone el registro con una dirección de informes de Cloudflare (`rua=mailto:...@dmARC-reports.cloudflare.net`) → Aceptar/«Add record» → política inicial `p=none` (solo observar; no cambia la entrega). A las 2-4 semanas, con los informes limpios (todo lo legítimo = IONOS con DKIM/SPF alineados), subir a `p=quarantine` (paso aparte, D6b). Alternativa manual: DNS → Records → Add → TXT · Name `_dmarc` (SOLO eso: Cloudflare añade el dominio) · Content `v=DMARC1; p=none; rua=mailto:engineering@nutrisynccollective.com; fo=1; adkim=r; aspf=r` · TTL Auto → Save (los informes XML llegan al buzón engineering@, ruidoso).	`dig TXT _dmarc.nutrisynccollective.com +short` devuelve `v=DMARC1; p=none; rua=mailto:...`. Un correo real de feedback@ a un Gmail → «Mostrar original» → `dmarc=pass` (junto a spf=pass y dkim=pass, como el 2-sep). Panel DMARC Management con volumen a la semana. Smoke: check DoH «dmarc existe y empieza por v=DMARC1».
F4 + F5 · Domains without HSTS (admin.nutrisynccollective.com y nutrisynccollective.com · Moderate)	UNA acción de zona cubre los dos (y m., v2. y cualquier host futuro): zona → SSL/TLS → Edge Certificates → «HTTP Strict Transport Security (HSTS)» → Change HSTS settings → acepto el aviso → Enable HSTS: ON · Max Age Header: `**6 months**` · **Apply HSTS policy to subdomains: solo si el inventario DNS del paso 0 muestra que TODOS los hosts responden en HTTPS** (los nuestros son Pages: sí; si hubiera un CNAME a algo sin TLS → NO) · Preload: `**OFF**` (irreversible en la práctica; se valora en GA) · No-Sniff Header: ON → Save. Comprobar antes que «Always Use HTTPS» está ON (SSL/TLS → Edge Certificates).	`curl -sI https://nutrisynccollective.com   grep -i strict-transport-security` → `max-age=15552000; includeSubDomains` (o sin includeSubDomains, según D1); lo mismo en admin., m., v2. Navegar el hub y StartUp Admin: sin cambios visibles. Smoke: check nuevo «HSTS presente en los 4 hosts». Los dos insights desaparecen. MARCHA ATRÁS: HSTS → OFF sirve `max-age=0`; los navegadores que ya la vieron tardan hasta el max-age en olvidarla (por eso 6 meses y sin preload).
F6 · Managed Rules not deployed (nutrisynccollective.com · Critical en el panel)	Paso 0 dice qué hay. (a) Si en Security → WAF → Managed rules aparece «Cloudflare Managed Ruleset» con botón Deploy (o «Free Managed Ruleset» apagado): Deploy con la acción por defecto de cada regla → Save. Es el conjunto reducido de Free (CVE de alto impacto): no toca peticiones normales, así que smoke, curl y Lighthouse siguen igual. (b) Si solo ofrece «Upgrade to Pro»: NO se contrata ahora (D2) — nuestro sitio no tiene origen propio que explotar (Pages estático + Functions + Supabase con su propio gateway), la única escritura pública ya va por Edge con Turnstile, y Pro son ~20 USD/mes (~240 €/año) por reglas pensadas para orígenes con aplicación detrás. Se archiva el insight con este motivo y se REVISAR EN GA (noviembre) con el tráfico real: si hay campaña y prensa, Pro también trae Super Bot Fight Mode con exclusiones (cierra F2) y más reglas de rate limiting.	(a) Security → WAF → Managed rules muestra el conjunto desplegado; smoke PRODUCCIÓN SANA y Lighthouse sin desafíos tras 24 h; Security → Events sin bloqueos a nuestras IP. (b) Insight archivado con motivo + item «revisar en GA» en el tablero.
F7 · Review unwanted AI crawlers with AI Labyrinth (nutrisynccollective.com · Low)	No es seguridad, es MARKETING: ¿queremos que los asistentes de IA (ChatGPT, Perplexity, Claude...) conozcan y citen la web de NutriSync? Hoy el bloque gestionado de Cloudflare en robots.txt les dice «no» y AI Labyrinth los castigaría. Se abre ☐ CF-1 (D4) para Pilar y Lucía con dos caminos: (A, recomendado pre-lanzamiento) PERMITIR: zona → Security → Bots (o Settings → Bot traffic) → «Block AI bots» / «Manage AI bots»: OFF y el bloque gestionado de robots.txt OFF → nuestro robots.txt vuelve a ser el único (Disallow solo /hub/, /v1/, etc.); AI Labyrinth OFF; se archiva el insight. (B) BLOQUEAR: dejar el bloque gestionado y activar AI Labyrinth (Security → Bots → AI Labyrinth: ON). Hasta la firma: nada cambia.	Con (A): `curl -s https://nutrisynccollective.com/robots.txt` ya no trae el bloque gestionado (el smoke lee por grupo `User-agent: *`, no cambia). Con (B): AI Labyrinth ON en el panel. En ambos: decisión firmada por las dos en ☐ e insight archivado.

Qué	Qué se hará (paso a paso)	Cómo se verificará
F8 · Domains without HSTS (app.laramagonzalez.com · Moderate) — FUERA DE NUTRISYNC	Misma receta que F4/F5 en la zona laramagonzalez.com (SSL/TLS → Edge Certificates → HSTS, 6 meses, subdominios solo si todos son HTTPS, sin preload). A criterio de Juanjo; no entra al tablero de NutriSync.	<code>`curl -sI https://app.laramagonzalez.com   grep -i strict`</code> .
F9 · Review unwanted AI crawlers (laramagonzalez.com · Low) — FUERA DE NUTRISYNC	Sitio familiar: casi seguro no quiere que lo rastreen. Security → Bots → «Block AI bots» ON y AI Labyrinth ON (gratis). A criterio de Juanjo.	Insight archivado o resuelto en el siguiente escaneo.
F10 · Bot Fight Mode not enabled (laramagonzalez.com · Moderate) — FUERA DE NUTRISYNC	Allí SÍ tiene sentido (no hay smoke ni curls que romper): Security → Bots → Bot Fight Mode ON. Si algún formulario o integración del sitio familiar falla después, OFF y anotarlo.	La web familiar sigue funcionando desde un navegador normal; insight resuelto.
F11 · Security.txt not configured (laramagonzalez.com · Low) — FUERA DE NUTRISYNC	Security → Settings → Security.txt con el correo personal de contacto y Expires a un año. A criterio de Juanjo.	<code>`curl -s https://laramagonzalez.com/.well-known/security.txt`</code> .
F12 · Users without MFA (juanjose.cebrian@outlook.com · Moderate) — CUENTA	Es la llave del garaje (Pages ×3, DNS, Access, Turnstile, GitHub comparte identidad). Pasos: (1) dash.cloudflare.com → icono de perfil → My Profile → Authentication → Two-Factor Authentication → Set Up → app de autenticación (la misma que ya usas) → código → activar; (2) descargar los <code>**backup codes**</code> y guardarlos en el gestor compartido con Pilar y Lucía (regla 11-ago: ninguna llave en una sola cabeza), NUNCA en el chat ni en el repo; (3) revisar Authentication → Active sessions y cerrar las que no reconozcas; (4) Manage Account → Members → Invite: Pilar (pgonzalez... o su gmail founder) como <code>**Administrator**</code> con 2FA obligatoria (Account → Configurations → «Enforce two-factor authentication»): continuidad real sin depender de tu móvil (D7). Lucía, si lo pide.	My Profile muestra 2FA «Enabled»; insight desaparece; la ficha del gestor compartido tiene los backup codes con fecha; Members muestra a Pilar aceptada y con 2FA. Prueba real: cerrar sesión y entrar con el código.
F13 · No Turnstile enabled (This account · Low)	Ya resuelto el 26-sep (widget «NutriSync web», UST-19 A, verificado con un alta real: ritmo-verificado=true). Nada que hacer: desaparece en el siguiente escaneo; si no, Archive con la nota.	Turnstile → Widgets muestra «NutriSync web» con tráfico; insight fuera del listado activo.
F14 · Vigilancia: que esto no envejezca (técnico, Claude)	smoke-prod.mjs suma tres checks (tras aplicar F1, F3, F4/F5): HSTS presente en los 4 hosts · security.txt en texto plano y con Expires > 30 días · <code>`_dmARC`</code> existe (DNS over HTTPS a dns.google, como el smoke ya hace con otras cosas). Y el paso mensual de Juanjo: Security → Insights → «Scan now» (o esperar al escaneo semanal) y pegar el listado en el chat.	smoke PRODUCCIÓN SANA con los tres checks nuevos; el listado de Insights baja de 13 a los archivados con motivo (F2, F6b, F7 hasta CF-1) + los 4 de laramagonzalez si Juanjo no los toca.

4 · Análisis de impacto

Dónde	Qué toca	Qué NO toca
Cloudflare · zona nutrisynccollective.com	SSL/TLS (HSTS), Security → Settings (security.txt, Insights archivados), Email (DMARC Management → 1 TXT nuevo en DNS), Security → WAF → Managed rules (si Free lo ofrece), Security → Bots (solo tras CF-1).	DNS existente (los CNAME de Pages, SPF, DKIM), Access/Zero Trust, la regla WAF de rate limiting de UST-19, Turnstile, Pages (ningún deploy hace falta salvo la alternativa de security.txt en repo).
Cloudflare · cuenta	2FA del usuario juanjose.cebrian@outlook.com; backup codes al gestor compartido; miembros (Pilar) con 2FA obligatoria.	La cuenta de GitHub (misma identidad, 2FA aparte), Expo, Apple, Google.
Correo	DMARC en <code>`p=none`</code> NO cambia la entrega: solo genera informes. Subir a <code>`quarantine`</code> es un paso aparte (D6b) con los informes en la mano.	SPF y DKIM (ya publicados), los buzones de IONOS, los crons que envían (digest, recordatorios, acuses).

Dónde	Qué toca	Qué NO toca
Web, hub, app	Nada de código. HSTS solo añade una cabecera (todo ya es HTTPS). security.txt es una URL nueva servida por Cloudflare.	Ningún po, ninguna OTA, ningún SQL. Las 8 legal, el hub, StartUp Admin, m. y v2. siguen igual.
Herramientas nuestras	smoke-prod.mjs: 3 checks nuevos (F14), tras aplicar los cambios (si no, gritarían hoy).	web-tests, pre-deploy, verify-web2, arneses.
Quién lo nota	Nadie desde fuera. Las founders: nada, salvo la invitación de Pilar a la cuenta de Cloudflare (D7) y la decisión CF-1.	Testers y usuarias de la app.
Riesgos	HSTS con «incluir subdominios» y un host sin TLS = ese host deja de abrir hasta 6 meses (por eso el inventario del paso 0 y sin preload). Managed rules (Free) bloqueando algo legítimo: improbable (solo firmas de exploits), se vigila en Security → Events 24 h. DMARC mal escrito: dns.google lo enseña en un minuto y se corrige. 2FA sin backup codes guardados = quedarse fuera de la cuenta: los códigos van al gestor ANTES de cerrar sesión.	

Coste: 0 € con las decisiones recomendadas. La única opción con precio (Pro, ~20 USD/mes) se deja como revisión en GA con tráfico real, no como acción ahora. Ningún proveedor nuevo.

5 · Decisiones (fila a fila — D1-D3 y D5-D9 Juanjo, carril técnico · D4 Pilar y Lucía, ☐ CF-1)

#	Propuesta	Alternativa	Decisión
D1	HSTS a nivel de zona (SSL/TLS → Edge Certificates): 6 meses, No-Sniff ON, preload OFF, «incluir subdominios» SOLO si el inventario DNS del paso 0 muestra que todos los hosts sirven HTTPS.	Cabecera `Strict-Transport-Security` en el `_headers` de cada proyecto Pages (3 proyectos, vive en el repo, exige un po por proyecto y no cubre hosts futuros).	
D2	WAF gestionado: desplegar el conjunto GRATUITO si el panel lo ofrece; NO contratar Pro ahora; archivar el insight con motivo y revisar en GA (noviembre) con tráfico real.	Contratar Pro ya (~20 USD/mes): WAF completo + OWASP + Super Bot Fight Mode con exclusiones + más reglas de rate limiting.	
D3	Bot Fight Mode / Super BFM: NO (mantiene D6 de UST-19); insight archivado con motivo; mitigación = Turnstile + rate limiting + Edge + REST cerrado.	Activar Bot Fight Mode (Free): desafiaría a smoke-prod, curl y Lighthouse sin posibilidad de excepción.	
D4 · ☐ CF-1 (Pilar y Lucía)	Rastreadores de IA: PERMITIR (quitar el bloque gestionado de robots.txt, sin AI Labyrinth) — una marca pre-lanzamiento gana si los asistentes de IA la conocen y la citan; el contenido de la web es público a propósito.	BLOQUEAR: mantener el bloque gestionado + AI Labyrinth ON (los rastreadores que ignoran robots.txt reciben enlaces trampa).	
D5	security.txt gestionado por Cloudflare (Security → Settings): Contact engineering@ y contact@, Expires a 1 año, idiomas en/es, Policy = privacidad.	Fichero `_integration/.well-known/security.txt` en el repo de webdeploy (copiado por integrate.py, probado por web-tests; exige un po).	
D6	DMARC con «DMARC Management» de Cloudflare (registro con rua a Cloudflare, informes en el panel), política `p=none`; D6b: a las 2-4 semanas con informes limpios → `p=quarantine`.	TXT manual con `rua=mailto:engineering@nutrisynccollective.com` (informes XML al buzón, sin panel).	
D7	2FA en la cuenta con app de autenticación + backup codes al gestor compartido + Pilar como Administrator con 2FA obligatoria (continuidad).	Solo 2FA, sin miembros nuevos (la cuenta sigue dependiendo de una sola persona).	
D8	laramagonzalez.com (F8-F11): fuera del ámbito NutriSync; recetas dadas, a criterio de Juanjo, sin tablero.	Tratarlas como parte de esta UST y verificarlas en el smoke (no: no es nuestro sitio).	

#	Propuesta	Alternativa	Decisión
D9	Verificación: 3 checks nuevos en smoke-prod (HSTS ×4 hosts, security.txt, `_dmarc` por DoH) tras aplicar los cambios + re-escaneo de Insights pegado en el chat.	Confiar en el escaneo semanal del panel sin checks propios.	

6 · Baseline, verificación y marcha atrás

Momento	Qué se comprueba
PASO 0 · Baseline (antes de tocar)	Los curl de F0 (HSTS en 4 hosts, security.txt), `dig TXT _dmarc` (vacío), captura del listado de Insights, estado de Managed rules en el panel, inventario DNS, lista de miembros. Pegado en el chat = foto de partida.
Orden de aplicación	F12 (2FA + backup codes al gestor, ANTES de nada: si algo sale mal en el resto, la cuenta sigue siendo tuya) → F3 (DMARC) → F1 (security.txt) → F4/F5 (HSTS, tras el inventario DNS) → F6 (managed rules, según lo que ofrezca el panel) → archivar F2 y, si aplica, F6 → F7 espera a CF-1 → F13 nada → F14 (smoke) → re-escaneo.
Después de cada paso	El curl/dig correspondiente de la columna «Cómo se verificará»; nada se da por hecho por el mensaje del panel (r16: «Deployed» no es «sirve»).
Marcha atrás	HSTS: OFF (sirve max-age=0; los navegadores que ya la vieron tardan hasta 6 meses en olvidarla — por eso sin preload). DMARC: borrar el TXT (vuelve al estado de hoy, sin informes). security.txt: Disable. Managed rules: Undeploy. 2FA: se puede desactivar desde el perfil con el código; los backup codes son la red. Insights archivados: Unarchive.
DoD	Los 9 hallazgos de NutriSync/cuenta resueltos o archivados con motivo escrito (F2, F6b, F7 hasta CF-1); smoke PRODUCCIÓN SANA con los 3 checks nuevos; `_dmarc=pass` en la cabecera de un correo real; 2FA activa y backup codes en el gestor compartido; CF-1 firmada por las dos (o abierta, con la web como hoy).

7 · What to Test (para Pilar y Lucía, cuando esté aplicado)

1. Nada debería cambiar a la vista: la web, el hub (Access + contraseña) y StartUp Admin abren igual; los correos de feedback@ siguen llegando (DMARC en modo observación no toca la entrega).
2. Pilar: aceptar la invitación a la cuenta de Cloudflare y activar el segundo factor al entrar (te lo pedirá el propio Cloudflare).
3. Las dos: ☐ CF-1 — ¿queréis que los asistentes de IA (ChatGPT, Perplexity, Claude...) puedan leer y citar la web de NutriSync? Recomendación: sí, antes del lanzamiento la visibilidad vale más que el control; se puede cerrar después si molesta.
4. Para Juanjo: en 2-4 semanas, el panel DMARC Management enseña quién envía en nombre del dominio; si todo es IONOS (alineado), se sube a `quarantine` (D6b).

8 · Lecciones grabadas (van también a CLAUDE.md)

Lección	Qué cambia
«Publicado» en la memoria no es «publicado» en el DNS	La lección del 2-sep decía que el TXT `_dmarc` se había creado con SPF y DKIM; dns.google del 27-sep dice que no existe. Todo registro DNS que se dé por hecho se comprueba desde fuera (dns.google) antes de escribirlo como hecho, y el smoke lo vigila.
La severidad de un escáner es genérica	«Managed Rules not deployed» sale Crítico en cualquier zona; en un sitio estático sin origen propio es moderado y la cura completa es de pago. Cada hallazgo se pesa contra nuestra superficie real y la decisión se escribe (hacer / no hacer con motivo / decisión de founders), no se persigue el verde.
Lo que no es seguridad no se decide como seguridad	Bloquear rastreadores de IA es una decisión de marketing y visibilidad de la marca: carril producto, ☐ para las dos, aunque el botón viva en la pestaña Security.

9 · La cadena

Paso	Estado
UST	Este documento (propuesta, 27-sep 01:3x). 13 hallazgos, uno a uno, con el hallazgo real medido (DMARC ausente).

Paso	Estado
Sign-off	Juanjo valida D1–D3 y D5–D9 fila a fila (carril técnico). Pilar y Lucía firman D4 (☐ CF-1) — no bloquea el resto.
Dev	Juanjo en el panel (F12 → F3 → F1 → F4/F5 → F6 → archivos); Claude: 3 checks en smoke-prod (F14) y, si D5 = repo, el fichero security.txt en integrate.py.
Test	curl / dig / dns.google tras cada paso; smoke PRODUCCIÓN SANA; Security → Events 24 h sin bloqueos propios.
Deployment	Todo es panel (sin po, sin OTA, sin SQL) salvo el smoke (repo del proyecto) y la alternativa D5.
Verification	Re-escaneo de Insights pegado en el chat; `dmarc=pass` en un correo real; 2FA activa; CF-1 en ☐.
hub + Notion	Hub: este doc 55 + adjunto; tablero: item S20 (HSTS · DMARC · security.txt · 2FA · smoke) + item «WAF gestionado: revisar en GA» + ☐ CF-1 (SQL de tablero). Notion: sin bloques → hub.

Firmas

Persona	Rol	Conforme	Fecha
Juanjo Cebrián	Ingeniería y producto (D1–D3, D5–D9, carril técnico; ejecuta en el panel)		
Pilar González	CEO · cumplimiento (D4 = ☐ CF-1; acepta la invitación a la cuenta de Cloudflare con 2FA; corrobora DMARC/HSTS)		
Lucía Cebrián	COO · diseño (D4 = ☐ CF-1: visibilidad de la marca en asistentes de IA)		